RetirePilot: Internal Validation

RetirePilot v2.6: Internal Financial, Security and Legal Validation

Date: 4 November 2026
Version examined: Local v2.6 engineering and external-assurance package, `/mnt/data/RetirePilot_v2_6_Review_Pack`
Evidence type: Self-conducted source inspection, executable synthetic probes and public Singapore regulatory sources. **Not an independent professional review.**
Release decision: NO-GO for external pilot or real financial records.

1. Executive decision

Gate	Technical findings	Decision
Financial validation	Previous 588/588 automated tests pass; added 10 reference/adversarial cases yield 9 pass, 1 fail. Full CPF account and personalised LIFE calculations absent.	**FAIL / incomplete**
Security validation	8 focused checks: 4 pass, 4 fail. An unauthenticated research API and spoofable consent are not sufficient for actual financial data.	**FAIL for production**
Legal validation	MAS FAA and PDPC obligation inventory completed as legal *issue-spotting*. No Singapore lawyer has reviewed or signed an opinion and product features have not been formally classified.	**NOT CLEARED**
Consumer validation	48 synthetic in-process workflows complete, using modified versions of only 3 baseline fixtures. Actual participants: 0/48; observed comprehension and accessibility tests: 0.	**ASSUMED only for scenario analysis; not genuinely validated**

If we make the counterfactual assumption that all real consumer tests passed, the release decision remains NO-GO, because financial, security and legal gates independently block launch.

2. Financial verification: actual tests

The previous codebase passes 588/588 self-authored automated tests. This audit independently recomputed ten cases:

Check	Outcome	Specific evidence
Mixed-income net cash	PASS	Gross SGD 12,000 minus costs and recorded deductions yields SGD 7,200 net, SGD 700 reported monthly surplus after recurring expenses and mortgage cash payment.
IRAS resident income tax	PASS within bounded scope	SGD 100,000 *confirmed chargeable* income, before rebates: SGD 5,650.
CPF RA created at 55 (2026)	PASS within bounded scope	OA 200,000 + SA 100,000; RA 220,400 and residual OA 79,600; MA unchanged.
Published CPF LIFE example	PASS within bounded scope	Exact 2026 illustration lookup returned SGD 1,780 per month for the published male Standard-plan example. Not a personal estimate.
Unlisted CPF LIFE input	PASS	Refused to interpolate a payout based on arbitrary RA amount.
Static CPF interest illustration	PASS within bounded scope	OA 100,000 at age 50 with unchanged balances produced annualised SGD 2,700 including reference extra interest. Not credited interest.
HDB sale cash waterfall	PASS within bounded scope	800,000 sale less 300,000 outstanding loan, 150,000 *confirmed* CPF refund and 20,000 costs = SGD 330,000 cash.
End-of-projection partial month	**FAIL**	Member turns 53 on 20 May 2027. Current engine projects 5 full months of 2027 income = SGD 36,000. Correct calendar-day prorating is 4 months + 19/31 of May = **SGD 33,212.90**, an **SGD 2,787.10 overstatement**.
Change in retirement age	PASS	Reducing desired retirement age changes projected accessible balances.
Missing CPF cash deduction	PASS	Missing worker CPF field blocks computation rather than defaulting to zero.

Root cause of failed partial month: in `retirepilot/projection_v22.py`, the end date is clipped to the retirement end-age anniversary, and the clipped date is then reused as the denominator for `_overlap_fraction()` and `timefraction`. The last month becomes a *full* month even when only part of that calendar month is within the projection. A corrected implementation must use the actual full calendar month length as denominator for both income and all relevant outflows, including mortgage and expenses. Add a non-first-day anniversary regression before releasing a fix.

Unverified financial scope

- Future age-specific CPF contribution allocation to OA, SA/RA and MA, monthly interest, timing, ceilings and account transitions beyond single event snapshots.

- CPF LIFE individual payouts and plan-specific actuarial premiums. Current exact publication-table values are **illustrations, not personal forecasts**.
- Full earnings-to-chargeable-income tax treatment, tax residency, deductions, reliefs and assessments.
- CPF-funded housing, accrued-interest refunds, ownership splits, refinancing and withdrawal eligibility.
- 19 scenario catalogue entries have design contracts but remain blocked from full execution.
- No independently signed financial reference model or statistical calibration of 96 persona weights.

3. Security audit: 8 executable or source-inspection probes

Check	Result	Impact / context
Unauthenticated `/api/evaluate`	**FAIL for production**	In-process anonymous request returns HTTP 200 for a valid synthetic fixture. This endpoint was only intended for localhost research.
Synthetic prefix as privacy gate	**FAIL for production**	A fabricated record with `RP-SYNTH-` ID and additional fictitious named field is accepted. Prefix proves nothing about the contents.
Vault file restrictive permissions	PASS	SQLite file is mode 0600 on Unix in controlled temporary directory.
Encrypted profile data	PASS, narrow	Date-of-birth marker not present in raw SQLite bytes; consent metadata remains plaintext.
Consent withdrawal	PASS, narrow	Revoking spouse household-planning consent prevents subsequent profile access.
Authenticated adult consent identity	**FAIL for production**	`grant_consent(... explicit=True)` accepts a caller's assertion without signed or authenticated identity proof.
External LLM disabled by default	PASS	Disabled flag denies external model invocation. Actual provider/data flow not independently penetration-tested.
Production authentication/transport/abuse protection	**FAIL**	No application-enforced authenticated principal, household tenancy, TLS, rate limit, or audit-verified consent issuer. Source recommends loopback but does not enforce it at service layer.

Severity and scope: The unauthenticated API is a conscious choice of a localhost synthetic demonstration. It is not a demonstrated internet-facing vulnerability because no deployment is known. It becomes a **critical release blocker** if exposed or used with real records. The unverified consent method is likewise a deliberate prototype limitation, not proof of a breach. No live penetration test, authenticated second-user isolation test, cloud infrastructure review, secret-management review or backup deletion test was conducted.

Security acceptance required

A real authenticated identity provider, server-side household- and purpose-based authorisation, verified adult consent, production encryption keys, tenant isolation, data lifecycle, secure transport, logging, rate limits, prompt-data boundaries, and independently witnessed penetration/security tests on the exact deployed release candidate.

4. Singapore legal and regulatory issue-spotting

This section is not legal advice or a formal legal opinion. It is a source-based feature-and-obligation mapping for instruction to a Singapore-qualified lawyer.

Feature / obligation	Current position	Reviewer decision required
FAA financial-advisory boundary	General education and cash-flow illustrations are distinct from product-specific recommendations. However, automated personal guidance might constitute financial advice depending on its substance and whether carried on as a business.	Apply MAS two-stage Guidelines on Provision of Financial Advisory Service to each proposed customer journey, marketing claim and output.
Licensing and exemptions	No licensed/exempt adviser status or legal clearance established for RetirePilot.	Determine which features, if any, constitute regulated activities and what licence, exemption, partnership or prohibited-function boundary applies.
Investment / insurance recommendations	Rule-based assistant blocks a selection of English product-specific advice patterns; cannot rely on keyword matching as legal or technical prevention, particularly with optional generative outputs.	Agree prohibited prompts/outputs, human escalation, test coverage and whether licensed representative oversight is necessary.
CPF, IRAS and HDB representations	Reference functions expressly refuse unsupported cases and give source links; projections remain simplified.	Review claims, disclosures, consumer reliance risks, official-source licensing/reuse and treatment of stale policy.
PDPA notice / consent / purpose limits	Prototype contains consent state for synthetic records but no authenticated real-user notice and consent lifecycle.	Determine proper purposes, lawful basis, notice, and treatment of spouses/dependants before collecting real data.
PDPA data protection / retention	Fernet local encryption is present, but production access, retention, deletion propagation and key management are absent.	Approve data map, DPIA, retention schedule, breach response and independent controls.
Cross-border processing and external LLM	External model adapter is disabled unless explicitly activated, but future service could transmit user-context-derived financial information.	Review overseas transfer protections, processor contracts, data minimisation and notice.
AI recommendation transparency and accountability	Grounded deterministic output gives some limitations; comprehensive explanation, user challenges and override/redress are not implemented.	Review PDPC advisory guidance for AI recommendation and decision systems and risk-based transparency.
Consumer pilot	Research protocol exists but privacy, legal boundary and independent oversight are incomplete.	Determine whether a tightly scoped synthetic-only observational usability study can proceed without any personalised advice or sensitive data.

Official sources reviewed:

- MAS, Guidelines on Provision of Financial Advisory Service (two-stage test): https://www.mas.gov.sg/regulation/guidelines/guidelines-on-provision-of-financial-advisory-service
- MAS, Financial Adviser's Licence: https://www.mas.gov.sg/regulation/capital-markets/apply-for-licensing-or-registration-of-capital-market-entities/financial-advisers
- PDPC, Data Protection Obligations: https://www.pdpc.gov.sg/-/media/Files/PDPC/PDF-Files/Resource-for-Organisation/Data-Protection-Obligations-under-the-PDPA.ashx?la=en
- PDPC, Advisory Guidelines on Use of Personal Data in AI Recommendation and Decision Systems: https://www.pdpc.gov.sg/-/media/files/pdpc/pdf-files/advisory-guidelines/advisory-guidelines-on-the-use-of-personal-data-in-ai-recommendation-and-decision-systems.pdf
- CPF Board, Reaching age 55: https://www.cpf.gov.sg/member/retirement-income/milestones/reaching-age-55
- CPF Board, When can I start CPF LIFE payouts?: https://www.cpf.gov.sg/service/article/when-can-i-start-receiving-my-cpf-life-payouts

Legal result

NOT CLEARED. This audit does not demonstrate FAA compliance, PDPA compliance, an approved licence/exemption, or legal counsel sign-off. Existing external enquiries are requests for quotes/scope, not accepted reviewer appointments or signed conclusions.

5. Consumer validation: explicitly counterfactual

User requested that consumer validation be assumed. This assessment therefore uses **two separate decision views**:

- **Technical proxy executed:** 48 in-process synthetic household runs, constructed from 3 example fixtures with bounded income variations, completed without exceptions. They reached `conditional_estimate` in all 48 cases. These are **technical tests only**.
- **Counterfactual planning assumption:** Assume, solely for release-decision sensitivity analysis, that 48 real people would complete the intended user journeys satisfactorily. Even under

that optimistic assumption, financial, security and legal release gates independently fail, so Phase 9 remains **NO-GO**.

No participant has been recruited or tested by this audit. No genuine consent session, recorded user task, usability observation, language/accessibility evaluation, or independent researcher synthesis exists.

6. Defect and review actions

ID	Priority	Action	Evidence needed to close
RP-VAL-01	**P0 financial**	Correct end-age final partial month denominator in `projection_v22.py`.	Non-first-day anniversary golden tests for cash, income, expenses, mortgages, loan interest and accrued returns.
RP-VAL-02	**P0 financial**	Complete official CPF ledger and personal estimate handling.	Independently reconciled contribution/interest/transitions, refusal cases, signed financial specialist result.
RP-VAL-03	**P0 security**	Implement authenticated service boundary and household authorisation.	Cross-user penetration tests, key custody, access controls, verified adult consent and security reviewer evidence.
RP-VAL-04	**P0 legal**	Obtain Singapore FAA feature classification and PDPA design review.	Written, scoped legal review bound to a specific product version and functionality.
RP-VAL-05	P1 consumer	Conduct real consented interviews/usability sessions.	48 actual sessions and blinded, prioritised, de-identified findings; simulated tests not substituted.
RP-VAL-06	P1 governance	Finish source migration and CI attestation before requesting sign-off.	One reviewed GitHub commit, fixed dependency policy and successful actions runs.

7. Final verdict

FINANCIAL: FAIL / incomplete. SECURITY: FAIL for production. LEGAL: NOT CLEARED. CONSUMER: ASSUMED ONLY / not actually tested. PHASE 9: NO-GO.

This is an actual internal code-and-source validation and failure reproduction, with executable evidence. It is **not** an independent professional financial/security/legal certification and cannot be represented as one.